

PASTA worksheet

Stages	Sneaker company
I. Define business and security objectives	• The app is for connecting sellers and shoppers, thus dealing with a lot of back-end processing. • The business values data privacy very highly. • The apps want to provide customers with ease of access and gain trust with how their data is protected.
II. Define the technical scope	List of technologies used by the application: • Application programming interface (API) • Public key infrastructure (PKI) • SHA-256 • SQL The technologies that should be prioritized for evaluation are SQL and API. Since a lot of the data is being transferred between them and these technologies are prone to vulnerabilities if the wrong security protocols and measures are applied. Data privacy has already been solved with encrypting the data, however we should still make sure the encryption works as intended.
III. Decompose application	Sample data flow diagram
IV. Threat analysis	• Session Hijacking : an internal threat that might occur as a result of weak login credentials from administrators, or other users. • SQL Injection : an external threat from a malicious hacker who might inject SQL queries in the application and receive sensitive data which is caused by a lack of prepared statements.
V. Vulnerability analysis	• Search queries can be endpoints in which SQL Injection may be executed to query the database. • The application uses a payment system, if user credentials are not encrypted correctly, the data will be vulnerable. • Weak passwords from user accounts and admin accounts can lead to hackers getting administrator privilege and the

	<i>entire app can be vulnerable to attacks.</i>
VI. Attack modeling	Sample attack tree diagram
VII. Risk analysis and impact	4 security controls that can reduce risk: • Prepared Statements to prevent the SQL database to be queried accidentally • Validate and sanitize user input to make sure that the user inputs what is expected. • Keep all software up-to-date to get the latest security features. • A password policy to make sure passwords are strong enough for users.
